

SIMATS ENGINEERING

ASSESSMENT TOOL 2

COURSE NAME: Ethical Hacking

COURSE CODE: ITA14

Name: K.Gokula

Reg No: 192312519

Q1. Footprinting Tools – Conducting Competitive Intelligence (15 Marks)

A passive security assessment involves collecting publicly available information without directly interacting with the target organization's systems. This helps identify potential security exposures while remaining non-intrusive.

1. Domain Registration Details

Tool: WHOIS

Command:

whois abctechnologies.com

Information Obtained:

- Domain owner/registrar
- Registration and expiry dates
- Name servers
- Administrative and technical contacts (if publicly available)

Role in Competitive Intelligence:

- Identifies domain ownership and registrar.
- Reveals domain age and renewal information.
- Helps understand the organization's online presence.

2. Employee Email Addresses

Tool: theHarvester

Command:

theHarvester -d abctechnologies.com -b google

Information Obtained:

- Employee email addresses
- Employee names
- Public hosts
- Associated domains

Role in Competitive Intelligence:

- Identifies employee email patterns.
- Helps understand organizational structure.
- Reveals publicly exposed contact information useful for security assessment.

3. Technology Stack Identification

Tool: Wappalyzer (Browser Extension) or BuiltWith

Information Obtained:

- Web server (Apache, Nginx, IIS)
- CMS (WordPress, Drupal)
- JavaScript frameworks (React, Angular)
- Programming languages
- Analytics and CDN services

Role in Competitive Intelligence:

- Identifies technologies used by the organization.
- Helps understand software versions and infrastructure.
- Assists in identifying technologies that may require security review.

4. Publicly Exposed Subdomains

Tool: Amass (Passive Mode) or Sublist3r

Command:

`amass enum -passive -d abctechnologies.com`

or

`sublist3r -d abctechnologies.com`

Information Obtained:

- Public subdomains
- Internet-facing services

Role in Competitive Intelligence:

- Discovers additional publicly accessible systems.
- Expands visibility into the organization's external footprint.
- Helps identify assets that should be included in authorized security assessments.

Summary Table

Tool	Purpose	Information Collected
WHOIS	Domain lookup	Domain registration details
theHarvester	Email enumeration	Employee emails, hosts
Wappalizer/BuiltWith	Technology identification	Web technologies, CMS, frameworks
Amass/Sublist3r	Subdomain enumeration	Publicly exposed subdomains

Conclusion:

These passive footprinting tools enable security professionals to gather publicly available information for competitive intelligence and authorized security assessments without directly interacting with the organization's servers.

Q2. DNS Zone Transfers (15 Marks)

A DNS zone transfer copies DNS records from the primary DNS server to secondary servers. If misconfigured, unauthorized users may retrieve sensitive DNS information.

Tool Used

dig

Command:

```
dig AXFR example.com @ns1.example.com
```

or

```
host -l example.com ns1.example.com
```

Successful Zone Transfer Example

example.com. IN SOA ns1.example.com admin.example.com

www IN A 192.168.1.10

mail IN A 192.168.1.20

ftp IN A 192.168.1.30

vpn IN A 192.168.1.40

dev IN A 192.168.1.50

Information Retrieved

1. Internal Hosts

Examples:

- server.example.com
- dev.example.com
- vpn.example.com

Use during reconnaissance:

- Identifies systems that may require security assessment.
- Reveals naming conventions and network structure.

2. Mail Servers

Example:

MX 10 mail.example.com

Use during reconnaissance:

- Identifies email infrastructure.
- Helps verify mail server configuration during an authorized assessment.

3. Subdomains

Examples:

- www.example.com
- ftp.example.com
- admin.example.com
- test.example.com

Use during reconnaissance:

- Discovers additional internet-facing services.
- Expands the scope of authorized security testing.

Security Risks of Misconfigured Zone Transfers

- Disclosure of internal infrastructure
- Exposure of subdomains
- Easier reconnaissance for attackers
- Increased attack surface visibility

Countermeasures

- Restrict zone transfers to authorized secondary DNS servers.
- Use Access Control Lists (ACLs).
- Disable public AXFR requests.
- Monitor DNS logs regularly.
- Keep DNS servers securely configured and updated.

Conclusion

An authorized tester can verify whether DNS zone transfers are permitted using:

```
dig AXFR example.com @ns1.example.com
```

If the transfer succeeds, the retrieved DNS records provide valuable information about hosts, mail servers, and subdomains that can guide further authorized reconnaissance and security testing.

Q3. Social Engineering Attacks and Countermeasures (20 Marks)**Scenario**

Employees receive an email claiming to be from the IT department asking them to verify their login credentials through a link because of an urgent security update.

Type of Social Engineering Attack

This is a **Phishing Attack**.

Definition:

Phishing is a social engineering attack where attackers impersonate trusted entities (such as the IT department) to trick users into revealing sensitive information like usernames, passwords, or financial data.

Characteristics of the Attack

- Pretends to be from the IT department.
- Creates urgency ("Urgent Security Update").
- Includes a malicious login link.
- Requests usernames and passwords.

Countermeasures**1. Verify the Sender**

- Check the sender's email address carefully.
- Be cautious of look-alike or spoofed domains.

2. Do Not Click Suspicious Links

- Hover over links to inspect the destination before clicking.
- If uncertain, navigate to the official website directly instead of using links in the email.

3. Never Share Credentials

- Legitimate IT departments should not ask users to submit passwords through email links.
- Enter credentials only on trusted, official login pages.

4. Report Suspicious Emails

- Notify the organization's IT or security team immediately.
- Reporting enables timely investigation and protective actions.

5. Enable Multi-Factor Authentication (MFA)

- MFA adds an additional verification step, reducing the impact of stolen passwords.

6. Security Awareness Training

- Educate employees to recognize phishing tactics.
- Conduct periodic phishing simulation exercises.

7. Email Security Controls

Organizations should implement:

- Spam and phishing filters
- Anti-malware scanning
- Domain protections such as SPF, DKIM, and DMARC

8. Keep Systems Updated

- Apply security updates regularly.
- Use up-to-date antivirus and endpoint protection software.

Conclusion

The attack is a **phishing attack** designed to steal employee login credentials by impersonating the IT department. Employees should verify the sender, avoid clicking suspicious links, never share passwords through email, report suspicious messages, and rely on security measures such as MFA, awareness training, and email security controls to reduce the risk of compromise.